

تقرير تحليل اختبار الاختراق

بوابة المراجعين — المرور العراقي

البند	القيمة
الموقع المختبر	applicants.itp.moi.gov.iq
البروتوكول / المنفذ	HTTPS — 443
تاريخ الاختبار	13/8/2026
التصنيف العام	حرج (Critical)
عدد الثغرات الحرجة	2 (مرتبطتان بسلسلة هجوم واحدة)

1. الملخص التنفيذي

أظهر تقييم الأمان لبوابة المراجعين التابعة للمرور العراقي وجود ثغرات أمنية حرجة تؤثر مباشرة على سرية بيانات المواطنين وعزل حساباتهم. يستطيع أي مهاجم على الإنترنت — دون صلاحيات إدارية — إنشاء حساب، تسجيل الدخول، ثم قراءة بيانات مواطنين آخرين تشمل الأسماء وأرقام الهواتف ومعلومات الطلبات وأرقام المركبات.

السبب الجذري: تعديل رأس Host في طلب HTTP للوصول إلى خوادم Backend داخلية (prod-beapplicants.itp.moi.gov.iq) عبر المضيف العام (bapplicants.itpmoi-prod.local) دون رفض من الخادم، يليه فشل في التحقق من الصلاحيات على مستوى البيانات (Broken Access Control و IDOR).

التوصية الإدارية: معاملة النتائج كحادث أمني P0 يتطلب تدخلاً فورياً من فريق البنية التحتية وفريق التطبيق معاً، ثم إعادة اختبار شامل قبل إعلان إغلاق الحادث.

2. الثغرات المكتشفة

2.1 تعديل رأس Host وكسر التحكم بالوصول (Critical)

البند	التفاصيل
الاسم	Host Header Manipulation and Broken Access Control
OWASP	A05:2021 Security Misconfiguration · A01:2021 Broken Access Control
CVSS تقديري	9.8 - 9.0

الوصف: النظام يوجّه الطلبات داخلياً إلى prod-beapplicants.itpmoi-prod.local، لكن تغيير قيمة Host إلى beapplicants.itp.moi.gov.iq يسمح بالوصول إلى واجهات Backend للتسجيل والمصادقة. الخادم يعالج الطلبات دون رفضها، فيُنشأ حساب Applicant جديد ويحصل على JWT صالح، ثم يُستخدم لاسترجاع سجلات تخص مستخدمين آخرين.

نقاط النهاية المتأثرة:

• POST /api/applicant/v1/auth/confirm-phone-number-send-otp

- POST /api/applicant/v1/auth/signup
- POST /api/applicant/v1/auth/login
- POST /api/applicant/v1/registrations/search
- GET /api/applicant/v1/requests/{requestId}

2.2 الوصول غير المصرح به — IDOR (Critical)

تمرير requestId مختلف إلى GET /api/applicant/v1/requests/{requestId} يُرجع تفاصيل طلبات مواطنين آخرين. كذلك POST /api/applicant/v1/registrations/search مع body { } يُرجع سجلات مركبات جميع المستخدمين.

الفرق الحاسم: النظام يتحقق من المصادقة (JWT صالح) ويفشل في التفويض (هل للمستخدم حق قراءة هذه البيانات؟).

3. سلسلة الهجوم

1. إرسال OTP للتحقق من رقم الهاتف
 2. إنشاء حساب مراجع جديد (signup)
 3. تسجيل الدخول والحصول على JWT
 4. البحث في جميع سجلات المركبات (Broken Access Control)
 5. الوصول لبيانات مواطن آخر عبر requestId (IDOR)
4. تقييم التأثير

التفاصيل	التقييم	البعد
PII لمواطنين متعددين	عالي جداً	السرية
إنشاء حسابات وهمية	متوسط	النزاهة
غير مباشر	منخفض	التوفر
لا يتطلب مهارات متقدمة	عالية	قابلية الاستغلال
انتهاك خصوصية بيانات مواطنين	حرج	الامتثال

5. التوصيات

- رفض أي Host غير مسموح على Gateway و Backend
- عزل internal-only — Backend
- إصلاح IDOR: التحقق من ملكية requestId
- إصلاح BAC: فلترة registrations/search حسب JWT
- Rate limiting على OTP / signup / login

• WAF rules لرؤوس Host غير المتوقعة

• Retest شامل بعد الإصلاح

6. جدول أولويات المعالجة

الأولوية	الإجراء	المسؤول
P0 — فوري	رفض Host غير مسموح	البنية التحتية
P0 — فوري	عزل Backend	DevOps / الشبكات
P0 — فوري	إصلاح IDOR	Backend
P0 — فوري	إصلاح BAC	Backend
P1 — عاجل	مراجعة جميع endpoints	Backend + QA
P2 — مهم	Retest شامل	فريق الاختبار

7. الخلاصة

التقرير يكشف سلسلة هجوم متكاملة: Misconfiguration (Host) → Broken Access Control → IDOR. يتطلب الإصلاح تنسيقاً بين البنية التحتية والتطبيق، ثم retest قبل إعلان إغلاق الحادث.

مصدر التحليل: تقرير اختبار الاختراق — بوابة المراجعين / المرور العراقي — 13/8/2026